L'Outil Hydra :

Les applications emploient souvent des mecanisme d'authentification pour protéger les données et fonctionnalités sensibles.
Parmi elle, l'Authentification HTTP de base (Basic Auth) est une methode rudimentaires mais courantes pour sécuriser les ressources web, en gros c'est un protocole de défi-réponses ou le serveur web exige les identifiants de l'utilisateur avant d'accorder l'acces aux ressources protégées, quand l'utilisateur essai d'acceder à une zone protégées le serveur renvoi un status Unauthorized avec une en-tête WWW-Authenticate invitant le navigateur de l'utilisateur à présenter une boite de dialogue de connexion. L'utilisateur fournit username et mot de passe qui sont encodés en base64 et inclusse dans l'en-tête Authorisation. Example (Authorization : Basic blocbase64)

Pour Bruteforcer cette authentification de base on peu utiliser le module http-get de Hydra. Voici ci-dessous une commande expliquée :

```
Agentpathogene@parrot$ hydra -L username.txt -P password.txt targetIP http-get /login/login.php -s 8080
```

http-get /login/login.php : Indique à Hydra que le serveur cible est un server http et que l'attaque doit être réalisé en utilisant des requetes GET à l'endpoint /login/login.php.
-s 8080 : définit le port utilisé par le service cible

Comprendre Formulaires de Connexion:

Au delà de la basic-auth de nombreux sites web utilisent des formulaires de connexion personalisés... Mais si leurs apparence change ils partagent souvent des mécanismes sous-jacent communs ... Souvent des formulaires HTML incluant un input pour le champ utilisateur un pour le mot de pass ainsi qu'un pour le bouton qui une fois pressé envoi une requete POST à un endpoint defini .. La requete contient le nom d'utilisateur et le mot de pass encodés sous forme clé-valeur. Il est necessaire de comprendre et maitriser le fonctionnement du formulaire cible avant d'essayer la menbre attaque, F12 et un Proxy Web peuvent nous aider à comprendre..
Voici-ci-dessous un exemple de requete de login typique :

```
POST /login HTTP/1.1
Host: www.example.com
Content-Type: application/x-www-form-urlencoded
Content-Length: 29

username=john&password=secret123
```

Le service http-post-form d'Hydra est spécifiquement conçu pour cibler les formulaires de connexion. Il automatise les requetes POST en insérant le nom d'utilisateur et le mot de pass directement dans le corps de la requete
Sa structure globale est la suivante :

```
Agentpathogene@parrot~$ hydra [options] target http-post-form "path:params:condition_string"
```

Dans ce module Hydra les conditions de reussites ou d'echec sont cruciales pour identifier correctement les tentatives de connexions valides et invalides. On a principalement des conditions d'echec (F=...) mais aussi de succes (S=...) exemple F="Invalid" ou S=302 pour une redirection ... pour ca qu'il est important de voir d'abord comment les requetes sont traitées et ce que le serveur renvoi ...

```
Agentpathogene@parrot~$ hydra -L user.txt -P pass.txt target http-post-form "/login:username=^USER^&password=^PASS^:F=Invalid password or username"
```